

SatsPath v2 Trust Model and Malicious-Server Invariants

Status: Draft / Normative Specification

Parent Epic: #46

Issue: #47

1. Executive Summary & Non-Negotiable Invariants

In SatsPath v2, resolution moves from unauthenticated transport/P2P mechanisms to an **authoritative, proof-carrying Server-to-Server (S2S) resolution protocol**.

Core Invariant

The server stores, logs, replicates, and serves identity data; it is *strictly forbidden* from *authoring identity changes*.

A self-signed profile alone is insufficient: a malicious or compromised registry could substitute both the identity key and profile while returning a self-consistent cryptographic signature. Similarly, a Merkle tree proof alone is insufficient if an adversarial server can construct bifurcated trees (split-view attacks) for different verifiers.

SatsPath v2 decouples **Integrity, Freshness, Global Consistency, Namespace Authority, Payment-Method Ownership**, and **Availability**. A binary **verified: true** flag is explicitly prohibited.

2. Actors & Compromise Model

Actor	Responsibilities	Key Type	Failure / Compromise Impact	Mitigation
Identity Owner	Authors profile updates, key rotations, revocations	secp256k1 (Schnorr/ECDSA)	Total loss of identity control if private key leaked	Monotonic sequence hash-chain, dual-signed rotation, revocation
Domain / Namespace Authority	Delegates authority to SatsPath server or publishes explicit namespace descriptor	DNSSEC KSK/ZSK or HTTPS WebPKI	Namespace hijacking, rogue server endpoint designation	DNSSEC validation, cryptographic namespace pinning, transparency logging
Log Operator	Appends valid name events to the Merkle tree; signs checkpoints	Operator secp256k1 Key	Can attempt split-view, rollback, or key substitution	Witness cosigning, dual-signed operator key rotation, public append-only tree

Actor	Responsibilities	Key Type	Failure / Compromise Impact	Mitigation
Authoritative Server & Replicas	Serves S2S envelopes over HTTP; syncs state	Transport TLS / API auth	Can drop requests (censorship), serve stale envelopes, or attempt omission	Monotonic checkpoints, maximum staleness bounds, multi-replica failover, out-of-band audit
Independent Witnesses & Monitors	Cosign log checkpoints after validating consistency proof	Witness secp256k1 Key	1 compromised witness cannot forge checkpoints if quorum M -of- N is enforced	Quorum threshold M/N , public cosignature gossip, automated alert logs
Recursive DNS Resolver	Resolves _satspath.<domain> TXT / URI records	N/A (Network intermediary)	Poisoned cache / spoofed record (if DNSSEC absent)	Mandatory DNSSEC verification or explicit TOFU pinning policy
Hosted Provider Administrator	Manages server infrastructure for hosted sub-identities (user@provider.com)	Infrastructure root / DB admin	Can censor or terminate account, but <i>cannot</i> forge transitions for existing user-held keys	Explicit “Hosted” trust rating displayed in UI; portable identity export
Client / Verifier Wallet	Verifies complete envelope locally before route selection	Local trust store / cache	Local cache poisoning if verification is bypassed	Verifier executes in isolated pure logic; fails closed on any invalid proof step

3. Trust Profiles

Every resolved identifier MUST evaluate to exactly one of the following canonical trust profiles:

Trust Profile

Domain-Sovereign
(DNSSEC Validated)

Domain/WebPKI
(HTTPS TOFU)

Hosted Identifier
(Provider Domain)

Explicit Pin /
Continuous Anchor

1. Domain-Sovereign

- **Description:** The user or entity owns the domain name (`example.com`) and publishes DNSSEC-signed `_satspath` delegation records pointing to their authoritative log.
- **Trust Anchor:** Root DNSSEC trust anchor (.) → Domain KSK/ZSK → `NamespaceDescriptor`.
- **Security Properties:** Protected against network MITM, DNS spoofing, and BGP hijacks. Full self-sovereignty.

2. Domain / WebPKI

- **Description:** Domain authority is discovered over HTTPS (`https://example.com/.well-known/satspath-authorit` but DNSSEC is absent or unvalidated).
- **Trust Anchor:** Public WebPKI CA hierarchy.
- **Security Properties:** Vulnerable to rogue CA issuance or DNS hijacking, but protected against passive eavesdropping and retrospective log tampering via witness signatures.

3. Hosted Identifier

- **Description:** The user has an identifier under a third-party domain (e.g., `alice@fiatjaf.com` or `bob@strike.me`).
- **Trust Anchor:** The hosting provider's namespace descriptor and log operator key.
- **Security Properties:** Provider can censor the user or refuse to log new updates, but *cannot* forge signatures on behalf of the user's existing identity key without cryptographic verification failure. **UI MUST clearly flag this as Hosted and NOT Domain-Sovereign.**

4. Explicit Pin / TOFU (Trust-On-First-Use)

- **Description:** Verifier establishes a local pin on first contact (`NamespaceDescriptorHash` + `LogId` + `RootHash`) and requires monotonic append-only continuity for all future resolutions.
- **Trust Anchor:** First verified checkpoint stored locally.
- **Security Properties:** Detects any subsequent unauthorized operator key swap, log fork, or namespace redirection.

4. Comprehensive Threat Matrix

Threat / Attack Vector	Attack Mechanism	Attacker Capability	Detection / Mitigation Mechanism	Terminal Error Code
Key Substitution	Malicious registry replaces user's public key with attacker's key in response	Full DB / Server control	Fails <code>verify_identifier_history()</code> : Registration event must be signed by initial key; subsequent keys require dual-signed <code>KeyRotation</code> .	<code>ERR_KEY_SUBSTITUTION</code>

Threat / Attack Vector	Attack Mechanism	Attacker Capability	Detection / Mitigation Mechanism	Terminal Error Code
Self-Signed Replacement	Server generates fresh fake profile and signs it with a newly generated fake key	Full DB / Server control	Fails <code>verify_checkpoint_inclusion()</code> : Leaf hash does not exist in the append-only log root committed by operator checkpoint.	ERR_INCLUSION_MISMATCH
Stale State Replay	Server returns a previously valid historical profile to rollback a rotation or revocation	Network / Server replay	Checkpoint sequence and timestamp checked against freshness policy and client's last observed sequence.	ERR_STALE_CHECKPOINT
Split-View / Equivocation	Server presents Root A to Client 1 and Root B to Client 2	Malicious Log Operator	Requires M -of- N independent witness cosignatures. Monitors detect inconsistent roots via RFC 6962 consistency proofs.	ERR_WITNESS_QUORUM_FAILED
Omission / Silent Deletion	Server omits a valid registered payment method or entire identity	Censoring Server	Authenticated Current-State Map generates cryptographic Non-Inclusion Proofs (Sparse Merkle Tree / Verkle Tree).	ERR_NON_INCLUSION_UNVERIFIED
Operator Key Swap	Attacker seizes server and signs checkpoints with an unauthorized operator key	Compromised Host	Checkpoints require valid <code>OperatorKeyRotation</code> signed by both old and new operator keys, adhering to monotonic sequence.	ERR_OPERATOR_ROTATION_INVALID
DNS Rollback / Spoofing	Attacker spoofs DNS records to redirect resolution to a rogue server	Active Network Adversary	DNSSEC validation fails or breaks explicit namespace pin.	ERR_DNSSEC_VALIDATION_FAILED
Compromised Witness	One witness colludes with malicious operator	Colluding Witness	Quorum requirement ($M \geq 2$) ensures single witness collusion is rejected.	ERR_INSUFFICIENT_WITNESSES

Threat / Attack Vector	Attack Mechanism	Attacker Capability	Detection / Mitigation Mechanism	Terminal Error Code
Malicious Replica	Out-of-sync or adversarial replica serves modified payload	Byzantine Replica	Every S2S response is a self-contained, verifiable envelope; client verifies Merkle proof against canonical root regardless of source.	ERR_ENVELOPE_VERIFICATION_FAIL
Lost Identity Key	User loses private key and attempts recovery	Disrupted User	Recovery is disabled by default unless a verifiable threshold multisig recovery policy was explicitly committed at registration.	ERR_RECOVERY_DISABLED
Hosted Provider Takeover	Provider revokes or claims account of user	Hostile Provider	History chain proves provider censorship; client UI flags hostile state; user can export cryptographically signed identity proof.	ERR_HOSTED_PROVIDER_CONFLICT
Denial of Service (DoS)	Server refuses to answer or floods garbage	Network Flooder	Fails gracefully to UNAVAILABLE without corrupting local verified state cache.	ERR_SERVER_UNAVAILABLE

5. Machine-Readable Verification States & Error Codes

A SatsPath v2 verification pipeline yields a structured result with explicit state classification:

```
#[derive(Debug, Clone, Copy, PartialEq, Eq, Serialize, Deserialize)]
#[serde(rename_all = "snake_case")]
pub enum VerificationStatus {
    /// Fully verified: valid DNSSEC, complete Merkle inclusion, witness quorum satisfied, payment method
    VerifiedSovereign,
    /// Verified against WebPKI authority or TOFU pin; witness quorum satisfied.
    VerifiedStandard,
    /// Verified hosted sub-identifier under third-party authority.
    VerifiedHosted,
    /// Verification failed due to cryptographic integrity or consistency violation.
    TerminalFailure,
    /// Server unreachable or timed out; cryptography untouched.
```

```

    Unavailable,
}

#[derive(Debug, Clone, Copy, PartialEq, Eq, Serialize, Deserialize)]
#[serde(rename_all = "SCREAMING_SNAKE_CASE")]
pub enum S2SErrorCode {
    // Namespace & Authority
    ErrDnssecValidationFailed,
    ErrNamespaceDescriptorMismatch,
    ErrAuthorityPinMismatch,

    // Identity & History
    ErrKeySubstitution,
    ErrInvalidEventSignature,
    ErrBrokenHistoryChain,
    ErrUnauthorizedKeyReplacement,
    ErrIdentifierRevoked,
    ErrRecoveryDisabled,

    // Merkle Log & Checkpoints
    ErrInclusionMismatch,
    ErrInvalidInclusionProof,
    ErrInvalidConsistencyProof,
    ErrCheckpointSignatureInvalid,
    ErrCheckpointRollback,
    ErrOperatorRotationInvalid,

    // Witnesses & Consistency
    ErrInsufficientWitnesses,
    ErrWitnessQuorumFailed,
    ErrConflictingCheckpoint,

    // Freshness & State
    ErrStaleCheckpoint,
    ErrNonInclusionUnverified,
    ErrProfileHashMismatch,
    ErrMethodBindingInvalid,

    // Transport & Network
    ErrServerUnavailable,
    ErrPayloadTooLarge,
    ErrMalformedEnvelope,
}

```

6. Explicitly Out of Scope for v2

1. **Custodial Funds Handling:** SatsPath does not hold, escrow, lock, or transfer Bitcoin or fiat funds.
2. **Forced Server Availability:** Cryptography proves correctness and detects equivocation, but cannot force an unresponsive server to reply.
3. **Email Inbox Proof:** Ownership of `user@domain.com` in SatsPath represents routing authority within the SatsPath namespace, not proof of SMTP/IMAP mailbox possession.
4. **Arbitrary Social Recovery:** No social or back-door recovery without pre-committed on-chain / cryptographic threshold scripts.